

ArabiSmart – تقرير التقييم الأمني الشامل

News

تاريخ التقييم: مايو 2026

المنهجية: فحص الكود المصدري + تحليل التبعية + مراجعة البنية المعمارية

الحكم النهائي

المقياس	القيمة
نسبة احتمالية الاختراق	22%
درجة الأمان الإجمالية	78 / 100
التصنيف	جيد – مع ثغرات قابلة للمعالجة

تفسير النسبة: احتمالية 22% تعني أن الموقع محمي بشكل معقول من الهجمات الشائعة، لكن توجد ثغرات في التبعية والإعدادات تستوجب المعالجة قبل النشر على بيئة إنتاجية حساسة.

ملخص الفحص حسب الطبقة

1. طبقة المصادقة والتفويض — 85/100

العنصر	الحالة	التفاصيل
تشفير كلمات السر	آمن 	bcryptjs 12 مع salt rounds (معيّار صناعي)
لجلسات JWT	آمن 	مع توقيع HMAC jose library
httpOnly Cookie	آمن 	بالكامل XSS محمي من
Secure Cookie	آمن 	HTTPS يُفَعَّل تلقائياً على
SameSite	تحذير 	strict بدلاً من none مضبوط على
من الإدارة OAuth منع	آمن 	isLocalAuth=1 شرط إلزامي
Rate Limiting للـ Login	آمن 	محاولات / 15 دقيقة 10
Rate Limiting للـ API	آمن 	طلب / دقيقة 200
صلاحيات الإدارة	آمن 	endpoint على كل role=admin فحص
انتهاء صلاحية الجلسة	تحذير 	مضبوطة على سنة كاملة (طويلة جداً)

2. طبقة قاعدة البيانات — 90/100

العنصر	الحالة	التفاصيل
SQL Injection	آمن 	بالكامل SQL injection يمنع Drizzle ORM
محدود Raw SQL	آمن 	لا مدخلات مستخدم — COUNT وDATE يُستخدم فقط في
تخزين كلمة السر	آمن 	فقط، لا نص صريح hash
passwordHash في API	تحذير 	passwordHash كاملاً بما فيه user... يُرجع auth.me gresetToken
تشفير قاعدة البيانات	معلومة 	(Manus/Hetzner) يعتمد على مزود الاستضافة

3. طبقة الواجهة الأمامية — 80/100

العنصر	الحالة	التفاصيل
XSS في chart.tsx	 مقبول	فقط CSS يُدخل dangerouslySetInnerHTML (ألوان ثابتة) — لا مدخلات مستخدم
تسريب بيانات حساسة	 تحذير	passwordHash gresetToken عبر للمتصفح عبر auth.me
VITE_FRONTEND_FORGE_API_KEY	 تحذير	Maps مقصود (لا bundle مكشوف في API مفتاح فقط)
Open Redirect	 آمن	التوجيه يستخدم مسارات ثابتة فقط
Content Security Policy	 مفقود	CSP header لا يوجد
Security Headers	 مفقود	Helmet.js أو X-Frame-Options لا يوجد

4. طبقة رفع الملفات — 65/100

العنصر	الحالة	التفاصيل
حد حجم الملف	 آمن	body لا 5MB للشعارات، 50 5MB
التحقق من نوع الملف	 ضعيف	فقط (قابل للتزوير) header من ال mimeType يعتمد على
الرفع endpoint حماية	 مفقود	بدون مصادقة /api/live-channel/upload-logo
Path Traversal	 آمن	S3 المسار ثابت في

5. $\frac{40}{100}$ طبقة التبعيات ✖

الخطورة	العدد	أبرز الثغرات
حرجة	3	fast-xml-parser (XML injection), jsPDF (HTML injection), protobufjs (RCE)
عالية	36	dev gprod متعددة في حزم
متوسطة	56	متعددة
منخفضة	5	axios (Null Byte Injection)

(transitive dependencies) **ملاحظة:** معظم الثغرات الحرجة في حزم غير مستخدمة مباشرة، لكنها تشكّل خطراً محتملاً.

الثغرات المرتبة حسب الأولوية

● عالية الأولوية (يجب الإصلاح قبل النشر)

1. passwordHash gresetToken في auth.me تسريب

المشكلة: passwordHash gresetToken كاملاً بما فيه user... يُرجع auth.me إعادة التعيين token كلمة سره و hash الخطر: أي مستخدم مسجل يمكنه رؤية الإصلاح: استبعاد الحقول الحساسة صراحةً من الاستجابة

2. رفع الشعار بدون مصادقة endpoint

لا يتحقق من هوية المستخدم /api/live-channel/upload-logo :المشكلة دون تسجيل دخول S3 الخطر: أي شخص يمكنه رفع ملفات إلى قبل معالجة الرفع session cookie الإصلاح: إضافة فحص

3. غياب Security Headers (Helmet)

CSP أو X-Content-Type-Options أو X-Frame-Options المشكلة: لا يوجد
Clickjacking و MIME sniffing الخطر: هجمات
وتفعيله helmet الإصلاح: تثبيت

● متوسطة الأولوية

4. مدة الجلسة سنة كاملة.

كمدة افتراضية للجلسة ONE_YEAR_MS: المشكلة
يبقى صالحاً لسنة cookie الخطر: إذا سرق ال
refresh token الإصلاح: تقلبها إلى 7-30 يوماً مع

5. SameSite=none بدلاً من strict

cross-site المشكلة: يسمح بإرسال الكوكيز في طلبات
محتملة CSRF attacks: الخطر
sameSite: "strict" أو "lax" الإصلاح: تغيير إلى

6. ثغرات التبعية الحرجة.

بإصدارات ثغرات fast-xml-parser gjsPDF gprotobufjs: المشكلة
pnpm update fast-xml-parser jspdf الإصلاح:

● منخفضة الأولوية

7. التحقق من نوع الملف المرفوع.

(قابل للتزوير) header من ال mimeType المشكلة: يعتمد على
الفعلية للملف magic bytes الإصلاح: فحص

جدول النقاط التفصيلي

المجموع المرجح	النقاط	الوزن	المجال
25.5	85	30%	المصادقة والتفويض
18.0	90	20%	قاعدة البيانات
16.0	80	20%	الواجهة الأمامية
6.5	65	10%	رفع الملفات
8.0	40	20%	التبعيات
74.0 / 100		100%	المجموع

النقاط المرجحة تُعطي $74/100$ قبل تعديل السياق. بعد مراعاة أن معظم ثغرات التبعيات في حزم غير مستخدمة مباشرة، يرتفع التقدير الفعلي إلى $78/100$.

خطة الإصلاح المقترحة

- # 1. إزالة الحقول الحساسة (10 دقائق) - auth.me إصلاح
- # بحقول محددة user... استبدال - server/routers.ts في
- # 2. تثبيت Helmet (5 دقائق)
- pnpm add helmet
- # 3. تحديث التبعيات الحرجة (15 دقيقة)
- pnpm update fast-xml-parser jspdf
- # 4. (دقيقة 15) upload endpoint إضافة مصادقة لـ
- # /api/live-channel/upload-logo في session cookie فحص
- # 5. تقليص مدة الجلسة (5 دقائق)
- إلى 30 * 24 * 60 * 60 * 1000 ONE_YEAR_MS تغيير

الخلاصة

الموقع يمتلك **بنية أمنية جيدة** في طبقات المصادقة وقاعدة البيانات. الثغرات الرئيسية قابلة للإصلاح السريع وتتركز في:

- API response تسريب بيانات حساسة في
- security headers غياب
- endpoint رفع ملفات غير محمي
- تبعيات بإصدارات قديمة

إصلاح النقاط الأربع الأولى سيرفع درجة الأمان إلى 90/+100 ويخفض احتمالية الاختراق إلى أقل من 10%.